

Sumário Executivo - N1 Pentest

Disciplina: Segurança da Informação

Professor: Claudinei Dias (Ney)

Integrantes: Rafael Dobner e André H. Voigt

Visão geral

O trabalho apresenta duas versões de uma API RESTful. A V1 foi criada de forma propositalmente insegura para demonstrar SQL Injection, XSS e CSRF em ambiente local. A V2 aplica controles de segurança para mitigar esses riscos.

Principais resultados

Os testes comprovaram as vulnerabilidades da V1. Na V2, as rotas protegidas exigem JWT, senhas são armazenadas com bcrypt, consultas são parametrizadas e operações sensíveis exigem token CSRF.

Conclusão

A comparação evidencia a importância de autenticação, armazenamento seguro de senhas, validação de entrada e controles contra ataques comuns em aplicações web.